FIELD GUIDE: DESIGNING AN AUTHORIZATION ARCHITECTURE

When choosing how to structure authorization in your systems, keep these guiding questions in mind:

- Where should enforcement happen? At the edge (API gateway)? In the app? Between services (sidecar)?
  - Choose based on trust boundaries and granularity of control.
- How close should decision-making be to the application?
  - Centralized PDPs offer consistency and auditability.
  - Distributed PDPs reduce latency and improve resilience.
- What context is needed to make decisions?
  - Identify required attributes: user roles, resource ownership, environment conditions.
  - Plan where that context lives and how it gets to the PDP (real-time or cached?).
- How will policies be authored and deployed?
  - Use version control and CI/CD for policies.
  - Prefer declarative, testable formats (policy-as-code).
- What needs to be logged and audited?
  - Centralize logs where possible.
  - Use a consistent schema.
- How will you handle outages and staleness?
  - Design for graceful degradation: cache policies and context where needed.
  - Monitor for drift between distributed components.

There’s no single correct deployment, but there is a correct fit for each use case. Align architectural decisions with your system’s goals for security, speed, scale, and simplicity.